TFG · SONDA PASIVA DE DETECCIÓN PQC · TAREA 1

Identificadores de algoritmos PQ e híbridos

Qué números busca la sonda en el handshake TLS y cómo se clasifican

Pablo Marugán Bastante · GITST, EPS-UAM · Tutor: Jorge E. López de Vergara | **03/11/2026** | Tutoría del miércoles 04/11/2026

1. Conclusión principal

> RESULTADO
>
> **El único registro oficial de identificadores es el de IANA** (*TLS Supported Groups*, actualizado el 28/10/2026). Contiene 3 grupos ML-KEM puros, 7 híbridos y 2 híbridos Kyber ya obsoletos. Solo uno es *Recommended*: **X25519MLKEM768 (0x11EC)**, el que usan Chrome, Firefox y Cloudflare. Todo se ha volcado a `sonda/grupos_pqc.csv` (90 grupos), que la sonda cargará al arrancar, y se ha validado sobre la traza del repositorio con Wireshark y tshark.

2. Dónde aparece el identificador

Cada algoritmo de intercambio de claves de TLS 1.3 tiene un número de 16 bits, el **NamedGroup**. La sonda no ve nombres de algoritmos: ve esos números en cuatro sitios del handshake, y cada uno significa algo distinto.

Mensaje · extensión	Qué significa	Para qué le sirve a la sonda
ClientHello · `supported_groups` (10)	Todo lo que el cliente **sabe hacer**	Clasificar al cliente
ClientHello · `key_share` (51)	Para qué grupos **ya manda su clave**	Saber si el servidor tenía PQ disponible sin coste
HelloRetryRequest · `key_share`	El servidor **pide** otro grupo	Servidor que fuerza PQ
ServerHello · `key_share`	Lo que el servidor **eligió** (una sola entrada)	Clasificar la conexión y, con matices, al servidor

3. Identificadores PQ e híbridos

Registrados en IANA

Hex	Nombre	Clase	Especificación	key_share cli / srv
0x0200–0x0202	MLKEM512 / 768 / 1024	PQ puro	draft-ietf-tls-mlkem-10	800/768 · 1184/1088 · 1568/1568
0x11E9 · 0x11EA	SecP256r1MLKEM512 · MLKEM512X25519	Híbrido	draft-rosomakho	—
0x11EB	SecP256r1MLKEM768	Híbrido	RFC 10024	1249 / 1153
0x11EC	**X25519MLKEM768**	**Híbrido**	**RFC 10024 · Recommended**	**1216 / 1120**
0x11ED	SecP384r1MLKEM1024	Híbrido	RFC 10024	1665 / 1665
0x11EE	curveSM2MLKEM768	Híbrido	draft-yang (curva china SM2)	—
0x11EF	MLKEM1024X448	Híbrido	draft-preussmattsson	—
0x6399 · 0x639A	X25519 / SecP256r1 + Kyber768Draft00	Híbrido obsoleto	Pre-estándar, marcado «D»	1216 / 1120 (X25519)

Fuera de IANA y «otros organismos»

- **Open Quantum Safe** (oqs-provider para OpenSSL) usa números del rango privado `0xFE00–0xFEFF` para FrodoKEM, BIKE y HQC, más algunas combinaciones de ML-KEM con otras curvas. Es tráfico de laboratorio, no de Internet. Los valores 0xFE30 y

0xFE31 coinciden con los que usó Cloudflare para Kyber en 2022-23, y por el número no se distinguen.

- **Organismos nacionales:** no existen registros nacionales de identificadores TLS. Aportan algoritmos, no números: China tiene su híbrido con SM2 en IANA (0x11EE); las curvas rusas GOST (0x0022–0x0028) son solo clásicas; HQC (respaldo elegido por NIST) y FrodoKEM (propuesto por agencias europeas) solo tienen números de OQS.
- **GREASE** (RFC 8701): Chrome añade valores falsos (0x0A0A, 0x1A1A … 0xFAFA) para que los equipos intermedios no se acostumbren a listas fijas. La sonda los detecta por patrón y los ignora.

4. El fichero `sonda/grupos_pqc.csv`

Recoge 90 grupos: 24 clásicos, 3 PQ puros, 7 híbridos, 2 híbridos obsoletos y 54 experimentales de OQS. Cada fila indica su fuente; donde ninguna fuente daba la longitud de la clave se ha dejado a 0 en lugar de calcularla.

```
id_hex,id_dec,nombre,clase,long_cliente,long_servidor,fuente
0x001D,29,x25519,clasico,32,32,IANA
0x11EC,4588,X25519MLKEM768,hibrido,1216,1120,IANA / RFC 10024
```

Por qué un fichero externo y no una tabla dentro del código: la reivindicación 8 de la patente prevé mantener actualizado el listado de algoritmos. Con el CSV, cuando IANA registre un grupo nuevo basta con añadir una línea, sin recompilar la sonda.

5. Prueba sobre `trazas/clienthello_pqc.pcap`

Realizada en Wireshark 4.6.9 (Windows) y tshark (Ubuntu en WSL). La traza contiene un handshake TCP, un ClientHello y un ServerHello.

Reensamblado: el ClientHello no cabe en un segmento

Observado en Wireshark	Explicación
[2 Reassembled TCP Segments (**1750 bytes**): #4(1460), #5(290)]	El ClientHello mide 1750 bytes. El máximo por segmento sobre Ethernet es **1460** (MTU 1500 − 20 de IP − 20 de TCP), así que viaja partido en dos paquetes.
Primeros bytes: `16 03 01 06 d1 01 00 06 cd 03 03`	Registro de handshake (0x16), versión 0x0301, longitud 0x06D1 = 1745; mensaje ClientHello (0x01) de 0x0006CD = 1741 bytes. 5 de cabecera + 1745 = 1750.

Extensiones y cruce con la tabla

```
frame  tipo  supported_group          key_share_group  key_exchange_length
5      1     0x11ec,0x001d,0x0017     4588,29          1216,32
6      2                              29               32
```

Grupo	Clase (CSV)	Longitud esperada	Observado
X25519MLKEM768 (0x11EC)	híbrido	1216 cliente	Anunciado 1° y con clave de 1216 bytes ✓
x25519 (0x001D)	clásico	32 / 32	Clave de 32 en el cliente; **elegido por el servidor**, 32 bytes ✓
secp256r1 (0x0017)	clásico	65 / 65	Solo anunciado, sin clave

La longitud total del `key_share` del cliente también cuadra: (2+2+1216) + (2+2+32) = 1256 bytes. La clave PQ es la que dispara el tamaño del ClientHello: sin ella, el mensaje rondaría los 530 bytes y cabría en un solo segmento. **Por eso el reensamblado TCP de la tarea 2 es obligatorio.**

Clasificación resultante

Elemento	Clasificación	Motivo
Conexión	**Insegura**	Se negoció x25519, solo clásico: vulnerable a «almacenar ahora, descifrar después».
Cliente 10.0.0.2	**Potencialmente inseguro**	Soporta PQ (y lo prefiere), pero también acepta grupos solo clásicos.
Servidor 140.82.113.4	**Inseguro**	Tenía la clave PQ del cliente y aun así eligió clásico. Es el único caso en que un servidor se clasifica con una sola conexión.

La traza es sintética (construida en la tutoría 1 como ejemplo): valida la tabla y el razonamiento, no el comportamiento real del servidor de GitHub.

> ★ **PARA COMENTAR EN LA TUTORÍA**
>
> Un **híbrido es seguro**: el atacante tendría que romper las dos partes, y un ordenador cuántico no rompe ML-KEM. Lo inseguro es negociar un grupo solo clásico. «Potencialmente inseguro» no describe una conexión, sino un **equipo** que soporta PQ pero también acepta clásico (reivindicación 9). Si el cliente *anuncia* PQ pero no manda su clave y el servidor acepta clásico sin HelloRetryRequest (el caso del 45 % de la tutoría 1), la conexión es insegura pero el **servidor queda indeterminado**: puede no saber PQ o no forzarlo. Distinguirlo exige **acumular estado por servidor**, que es lo que pide la patente y lo que no hace tlscensus.

6. Fuentes

- IANA, *TLS Parameters – TLS Supported Groups*: iana.org/assignments/tls-parameters (consultado 03/11/2026)
- Kwiatkowski et al., *Post-quantum hybrid ECDHE-MLKEM Key Agreement for TLSv1.3* (RFC 10024)
- Connolly, *ML-KEM Post-Quantum Key Agreement for TLS 1.3*, draft-ietf-tls-mlkem
- Open Quantum Safe, oqs-provider, *ALGORITHMS.md*: github.com/open-quantum-safe/oqs-provider
- Westerbaan (Cloudflare), sustitución de 0x6399 por 0x11EC, lista de correo TLS del IETF, sept. 2024